LockBit Ransomware Analysis: Citrix Bleed Exploitation & Incident Response Case Study

By

Vignesh Reddy sama

Executive Summary:

- In October 2023, the LockBit ransomware group exploited Citrix Bleed (CVE-2023-4966) to gain unauthorized access to Boeing's network.
- Attackers stole 40GB of sensitive data, including Citrix logs, email backups, and security configurations. Boeing refused the $200 million ransom, leading to public data exposure.
- The breach impact disrupted Boeing's parts and distribution business, affecting the global supply chain for critical aircraft components.
- The Techniques LockBit affiliates used PowerShell scripts, remote access tools (AnyDesk, Splashtop), and DLL injections to maintain persistence.
- Recommendations include patching vulnerabilities, enforcing MFA, strengthening network monitoring, restricting unauthorized remote access tools, and improving incident response plans to prevent future threats.

Case Overview:

Boeing, a global aerospace and defense leader, was targeted by the LockBit ransomware group in October 2023. Attackers exploited Citrix Bleed (CVE-2023-4966) to hijack NetScaler session cookies, bypassing authentication and infiltrating Boeing's systems. They deployed PowerShell scripts, remote access tools, and persistence mechanisms, exfiltrating 40GB of sensitive data. Boeing refused to pay the $200 million ransom, leading to the data being leaked online. While flight safety remained unaffected, the attack disrupted Boeing's parts and distribution business. This breach underscores the need for stronger cybersecurity measures, including patching vulnerabilities, enforcing MFA, and enhancing network monitoring.

Key Findings:

- Citrix Bleed Exploit: Attackers leveraged CVE-2023-4966 to steal NetScaler session cookies, bypassing authentication [1].
- Unauthorized Remote Access: Deployed PowerShell scripts, AnyDesk, and Splashtop to maintain persistence [1].
- Significant Data Exfiltration: Attackers stole 40GB of sensitive data, later leaked after ransom refusal [1].
- Indicators of Compromise (IoCs): Included malicious IPs, domains, PowerShell scripts, and scheduled tasks [1].
- Operational Impact: Affected Boeing's parts and distribution business, though flight operations remained safe [1].

Recommended Mitigation Strategies:

- Patch Management: Regularly update Citrix NetScaler and other critical software [1].
- Access Controls: Enforce MFA and session validation to prevent unauthorized logins [1].

- Network Monitoring: Deploy Intrusion Detection Systems (IDS) to detect suspicious activities [1].
- Endpoint Security: Restrict unauthorized remote access tools like AnyDesk and Splashtop [1].
- Incident Response Plan: Develop a ransomware containment strategy and conduct regular cybersecurity training [1].

Threat Intelligence Plan:

- **Strategic Level:** What long-term cybersecurity strategies should Boeing implement to defend against evolving ransomware threats like Lock Bit?
- **Operational Level:** What security gaps were exploited? How effective was the response to the breach?
- **Tactical Level:** What Indicators of Compromise (IoCs) were associated with this attack? How can Boeing improve real-time threat detection?

Incident Analysis and IOCs:

- IP Addresses & Domains:
    - 192.229.221.95 (Command-and-Control Server)
    - 81.19.135.219 (Used for malicious file downloads)
    - 185.229.191.41 (Linked to AnyDesk remote access tool)
    - adobe-us-updatefiles.digital (Fake domain for data exfiltration)
- Malicious Files & Registry Entries:
    - 123.ps1 – PowerAdobelib.dll & Mag.dll – Malicious DLL files used to maintain persistence
    - Scheduled Tasks: Created fake Windows tasks such as "UpdateAdobeTask" to re-establish access

- Exploitation & lateral movement tools

    - Plink.exe – SSH tunnelling and remote connections.[1]
    - AnyDesk, TeamViewer, Splashtop, Zoho Assist, ScreenConnect, FixMe.IT – Remote desktop tools for persistence.[1]
    - PsExec.exe & wmiexec.exe – Lateral movement and remote command execution.[1]
    - Netscan.exe – Network scanning tool to identify targets.[1]
    - Mimikatz.exe & secretsdump.py – Credential dumping tools for authentication hijacking.[1]

- Citrix Bleed (CVE-2023-4966)

  CVE-2023-4966, also known as Citrix Bleed, is a sensitive information disclosure vulnerability affecting NetScaler ADC and NetScaler Gateway when configured as a Gateway or AAA virtual server [4]. This flaw allows attackers to hijack session tokens, bypass authentication, and gain unauthorized access. The NIST CVSS score rates it as 7.5 (High), while Citrix assigns a 9.4 (Critical) rating, highlighting its severe impact. Affected versions include NetScaler ADC and Gateway 12.1, 13.0, 13.1, and 14.1 before their respective patched releases. CISA has included this vulnerability in its Known Exploited Vulnerabilities (KEV) Catalog, urging organizations to apply patches immediately and terminate all active sessions to mitigate potential threats [4].

Controls to Mitigate Incidents (CIS Controls v8)

- Inventory and Control of Enterprise Assets: Monitor all Citrix NetScaler appliances [1].
- Continuous Vulnerability Management: Prioritize patching of CVE-2023-4966 and other critical vulnerabilities [1].
- Email and Web Browser Protections: Block access to malicious domains used in ransomware attacks [1].
- Malware Defences: Deploy Endpoint Detection and Response (EDR) to detect PowerShell and DLL attacks [1].
- Security Awareness & Training: Educate employees on phishing risks and unauthorized remote access tools [1].

Control	Description
CPG 1. E	Patch known exploited vulnerabilities within 24-48 hours.
CPG 2. B	Enforce strong password policies (minimum 15 characters).
CPG 2.C	Implement multi-factor authentication (MFA).
CPG 2. E	Restrict PowerShell and administrative tool usage.
CPG 2.T & 2. U	Enable advanced logging and SIEM monitoring
CPG 2. W	Secure Remote Desktop Protocol (RDP) & remote access.

Table 1: CISA controls [1]

MITRE ATT&CK Techniques Used:

Techniques	Tactics	Description
T1556.006	Credential Access	Bypassing Multi-Factor Authentication (MFA).
T1539	Credential Access	Stealing session cookies for authentication hijacking.
T1082	Discovery	Gathering system information for exploitation.
T1563	Lateral Movement	Hijacking user sessions for privilege escalation.

Table 2: MITRE ATT&CK Techniques & Tactics [1]

Course of action matrix:

Kill Chain Phase	Discover	Detect	Deny	Disrupt	Degrade	Deceive	Destroy
Reconnaissance	Network traffic analysis for vulnerabilities	Monitoring for reconnaissance tools (e.g., NetScaler scans)	Block suspicious geolocated IPs	Block suspicious geolocated IPs	Reduce attack surface by disabling unused ports	Use honeypots to lure attackers	Remove any active attacker sessions and trace back to source
Weaponization	Discover use of known exploits (CVE-2023-4966)	Detect exploitation patterns related to Citrix Bleed	Patch systems to mitigate CVE-2023-4966	Disable vulnerable NetScaler appliances	Apply patches immediately	Mislead attackers about system configurations	Destroy malicious payloads and tools
Delivery	Examine incoming traffic for suspicious HTTP headers	Detect crafted GET requests with malformed Host headers	Block unauthorized access based on signature	Deploy WAF to block malicious traffic	Block known malicious s IPs	Deploy deceptive systems to waste attacker resources	Block further malicious file deliveries
Exploitation	Monitor for exploitation of session hijacking via NetScaler	Detect hijacked sessions through anomalous login behavior	Enforce MFA and username/password validation	Detect and disrupt session hijacking tools	Rate-limit sensitive services to slow down exploitation	Mislead attackers with fake session data	Destroy hijacked sessions and reset credentials
Installation	Monitor file integrity and newly installed	Detect execution of PowerShell	Prevent execution of unapproved scripts	Quarantine suspicious files and executables	Disable RMM tools (AnyDesk,	Feed false system information to attackers	Delete malicious files and terminate processes

	software (e.g., PowerShell scripts)	l scripts (123.ps1)			Splashtop)		
Command and Control	Inspect for signs of remote command	Detect communication with known C2 servers (e.g., Adobe-us-update files)	Block C2 domains and IPs	Disrupt communication by blocking C2 IPs	Slow down data exfiltration through throttling	Use decoy C2 systems to mislead attackers	Cut off all C2 communication channels
Action on Objectives	Detect abnormal data access patterns and exfiltration	Monitor for large outbound data transfers (e.g., 40GB of data)	Block data exfiltration paths (e.g., via AnyDesk)	Disrupt data exfiltration using network segmentation	Degrade attacker access to critical assets	Use deceptive data to mislead attackers	Delete exfiltrated data and wipe affected systems

Conclusion:

The Boeing data breach underscores the critical risks posed by unpatched vulnerabilities and ransomware attacks. Lock Bit affiliates exploited Citrix Bleed (CVE-2023-4966) to bypass authentication, deploy persistence mechanisms, and exfiltrate 40GB of sensitive data, disrupting Boeing's parts and distribution business [1]. The refusal to pay the $200 million ransom led to public data exposure, emphasizing the need for proactive cybersecurity measure [1]. To prevent future incidents, Boeing must prioritize timely patching, enforcing MFA, network segmentation, and advanced endpoint detection [1]. Implementing frameworks like MITRE ATT&CK [2], the Cyber Kill Chain [3], and CISA security controls [1] will enhance threat detection and incident response. Restricting unauthorized remote access tools, improving real-time threat intelligence, and conducting regular cybersecurity training will further strengthen security [1]. This breach highlights the growing ransomware of cyber threats and the necessity for continuous monitoring, risk assessment, and adaptive defense mechanisms to mitigate vulnerabilities and enhance Boeing's cybersecurity resilience [1].

References:

[1]. CISA, "LockBit 3.0 Ransomware Affiliates Exploit Citrix Bleed," Cybersecurity Advisory AA23-325A, 2023.

[2]. MITRE ATT&CK Framework, "Enterprise Tactics & Techniques," https://attack.mitre.org/, accessed March 25th 2025.

[3]. Lockheed Martin, "Cyber Kill Chain," https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html, accessed March 25th 2025.

[4]. National vulnerability database 'CVE-2023-4966'accessed March 25th 2025.